

INTRODUCTION AU TEST D'INTRUSION

Guide du TP 1

TP 1 · Lire une lettre de mission

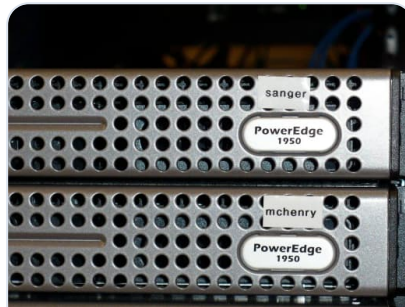


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Ordinateur portable

L'ordinateur que l'on emporte partout



Serveur

Fournit fichiers, messagerie ou site web aux autres

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Serveur, Florence Devouard, CC BY-SA 4.0.

À RETENIR

- ◆ Cadre et limites : tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des valeurs inventées hors du scénario ; ils montrent une méthode et jamais une réponse du labo.

1 Classer une cible

Lis d'abord la liste exacte des noms et des blocs autorisés dans la lettre de mission.

Ensuite, classe chaque ligne de cibles découvertes avec trois questions simples : le nom est-il exactement listé ; l'adresse observée appartient-elle au bon bloc ; un doute explicite reste-t-il écrit dans la ligne ?

Si le nom est exact et le bloc correct, tu ranges en périmètre.

Si le nom est bon mais que le bloc sort de la plage autorisée, tu ranges hors périmètre pour raison réseau.

Si le nom ressemble au client mais n'apparaît pas dans la liste exacte, tu ranges à clarifier tant que la lettre ne le confirme pas.

2 Classer une action

Une action se lit en croisant la cible, la famille, l'intensité, l'horaire et les comptes de test.

Une action passive sur une cible hors périmètre reste interdite.

Une bonne cible n'autorise pas tout : la famille peut être dans la liste jamais autorisée, l'intensité peut dépasser le plafond, ou l'action peut tomber hors fenêtre.

Si une action authentifiée vise un portail sans compte livré, elle ne devient pas autorisée par optimisme : elle reste à clarifier.

Si une preuve touche des données sensibles, cherche si un contact juridique doit valider avant exécution.

3 Visionneuse du site

Dans la visionneuse, commence par rechercher les mots « autorisé », « jamais », « compte » et « doute ». Note ensuite un tableau à trois colonnes : en périmètre, interdit, à clarifier.

4 Exemple Bash sur des cibles inventées

BASH

```
cat > guide-cibles.csv <<'EOF'
id,cible,type,source,ip_observee,justification,doute
X01,atelier-baobab.example,site,registre-dns,192.0.2.10,nom exact,no
X02,api.atelier-baobab.example,api,journal-ct,192.0.2.11,sous-domaine non cité,yes
X03,atelier-baobab.example,site,note,192.0.3.10,bloc voisin,no
EOF
awk -F, 'NR>1 {
    if ($7=="yes") print $1 ": clarifier";
    else if ($2=="atelier-baobab.example" && $5 ~ /^192\.0\.2\.\/) print $1 ": en-périmètre";
    else print $1 ": interdit";
}' guide-cibles.csv
```

5 Exemple PowerShell 5.1 sur des cibles inventées

POWERSHELL

```
@(
    'id,cible,type,source,ip_observee,justification,doute',
    'X01,atelier-baobab.example,site,registre-dns,192.0.2.10,nom exact,no',
    'X02,api.atelier-baobab.example,api,journal-ct,192.0.2.11,sous-domaine non cité,yes',
    'X03,atelier-baobab.example,site,note,192.0.3.10,bloc voisin,no'
) | Set-Content -Encoding UTF8 guide-cibles.csv
Import-Csv -Encoding UTF8 guide-cibles.csv | ForEach-Object {
    if ($_.doute -eq 'yes') { "$($_.id): clarifier" }
    elseif ($_.cible -eq 'atelier-baobab.example' -and $_.ip_observee -like '192.0.2.*') { "$($_.id): en-périmètre" }
    else { "$($_.id): interdit" }
}
```

6 Exemple Bash sur des actions inventées

BASH

```
cat > guide-actions.csv <<'EOF'
id,action,cible,famille,validation_requise,intensite,horaire_utc
B01,lire les DNS,atelier-baobab.example,passive,aucune,basse,09:00
B02,ouvrir le portail sans compte,espace-client.example,authentifie,aucune,basse,09:10
B03,phishing MFA,atelier-baobab.example,ingenierie_sociale,aucune,basse,09:20
EOF
awk -F, 'NR>1 {
    if ($4=="ingenierie_sociale") print $1 ": interdit";
    else if ($4=="authentifie") print $1 ": clarifier";
    else print $1 ": autorisé";
}' guide-actions.csv
```

7 Exemple PowerShell 5.1 sur des actions inventées

POWERSHELL

```
@(
    'id,action,cible,famille,validation_requise,intensite,horaire_utc',
    'B01,lire les DNS,atelier-baobab.example,passive,aucune,basse,09:00',
    'B02,ouvrir le portail sans compte,espace-client.example,authentifie,aucune,basse,09:10',
    'B03,phishing MFA,atelier-baobab.example,ingenierie_sociale,aucune,basse,09:20'
) | Set-Content -Encoding UTF8 guide-actions.csv
Import-Csv -Encoding UTF8 guide-actions.csv | ForEach-Object {
    if ($_.famille -eq 'ingenierie_sociale') { "$($_.id): interdit" }
    elseif ($_.famille -eq 'authentifie') { "$($_.id): clarifier" }
    else { "$($_.id): autorisé" }
}
```

8 Check-list avant de répondre

- ◆ Pour une cible : nom exact, bon bloc, doute éventuel.
- ◆ Pour une action : cible, famille, intensité, horaire, compte de test, validation juridique.
- ◆ Pour un comptage : écris d'abord la règle de ce qui compte avant de sommer.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).